

Authority Aware Underwriting - How GAuth Supports Liability Analysis and Loss Control

Abstract

GAuth enforces delegated authority. Insurance transfers specified financial consequences of risk. An authorised action can still be erroneous; an accurate action can still be unauthorised. These distinctions matter both before a loss and when allocating responsibility afterwards.

For an underwriter, the proposition is straightforward: an agent's identity and access rights do not necessarily establish the financial or operational authority given to it for a particular assignment. GAuth adds a separately evidenced instruction from the insured or other responsible principal: what this agent may do, for whom, for how long and within which limits. When that instruction is checked before execution, it can become a testable loss-prevention control rather than a statement of intent.

This RFC connects that control to the insurance lifecycle: submission, risk engineering, quotation and binding, ongoing exposure monitoring, claims investigation and renewal. It does not make the insurer an approver of individual transactions. Section 3.1 describes the normal course of business; §4.4 compares the same loss scenario with and without GAuth; §8.4 explains the incremental underwriting value over existing safeguards.

Gimel proposes collaboration with insurers around three contributions:

1. **Authority evidence for liability analysis:** establish what authority existed, what the agent did, what the relying party received or verified, and how those facts relate to a loss.
2. **Loss control:** restrict the executable consequences of model errors, prompt-induced instructions and unauthorised delegation through enforced authority boundaries.
3. **Evidence-based underwriting:** test whether demonstrated controls reduce loss frequency, severity or aggregate exposure sufficiently to influence coverage terms or pricing.

An agent exceeding its authority while a relying party knowingly accepts the action presents a different factual situation from an agent exceeding authority without that party receiving the limitation. GAuth-related evidence can help distinguish these

situations. It does not itself determine legal knowledge, causation, liability or insurance coverage.

As an example, Munich Re's aiSure and Ergo Next illustrate AI-performance risk assessment and financial risk transfer. Instnt illustrates identity/fraud-risk decisioning combined with insurance. Neither is described here as a substitute for action-specific delegated authority. All examples illustrate potential complements; the proposed approach remains open to other insurers and technology providers.

Status of This Memo

This document is published as a work-in-progress draft and is currently under review by insurers. No insurer characterization is original analysis without an attributed source. The collaboration framework is the original value-add of this document; the descriptions are aggregated public material.

This is a Gimel Foundation Standards Track document. It represents the current consensus of the Gimel Foundation community pending the insurer-review cycle. Information about the status of this document, any errata, and how to provide feedback may be obtained at <https://gimelfoundation.com> or <https://github.com/Gimel-Foundation>.

Legal notice

Copyright (c) 2026 Gimel Foundation and the persons identified as the document authors. All rights are reserved.

This document is subject to GiFo-RFC 0080 (Gimel Foundation Legal Provisions Relating to GiFo Documents), GiFo-RFC 0090 (Gimel Foundation Rights in Contributions), and GiFo-RFC 0100 (Gimel Foundation Intellectual Property Rights Policy) in effect on the date of publication of this document (see <http://GimelFoundation.com> or <https://github.com/Gimel-Foundation>). Please review these documents carefully, as they describe your rights and restrictions with respect to this document.

This specification is published under the Apache License 2.0, consistent with GiFo-RFCs 0110, 0111, 0115, 0116, 0117, 0118, 0140, 0141 and its associated specifications.

This proposal does not amend a normative specification, create insurance coverage or prescribe actuarial methodology. It invites evaluation of a collaboration, not acceptance of an existing insurer integration. Technical capabilities require validation for the exact deployment. Product names identify their respective owners; no sponsorship, approval or affiliation with Gimel is implied. MunichRe, Instnt and Ergo Next are referenced descriptively as the most fully-specified reference case for the category defined herein.

1. What is being insured, and what the control does

The proposal concerns agents capable of consequential actions: transactions, data disclosures, tool calls, infrastructure changes and delegated work. It does not claim to establish model correctness, eliminate fraud, supply a legal liability shield or guarantee lower premiums.

Principal means the person or organisation granting authority. **Agent** means the actor exercising it. **Relying party** means the person or system accepting or acting upon the agent's request, such as a merchant, API operator or counterparty; it need not be the insured. **Mandate** means a signed, scoped delegation binding the principal, agent, permitted actions/resources, validity and lifecycle conditions.

Authority contraction is used descriptively for non-expanding delegated or task-specific authority. It is aligned with the narrowing and monotonicity concepts in the reviewed GAuth/CCPE materials, not introduced as a new protocol primitive or product name.

Evidence labels used throughout:

- **Documented:** supported by the identified source, not independently certified.
- **Proposed:** a collaboration or pilot requirement, not a deployed interface.
- **Hypothesis:** a benefit to measure, not a proven result.
- **Unknown:** not established by reviewed evidence; not proof that a capability cannot exist.

The GAuth name is used for the open-standard/open-core authority approach, subject to applicable designation rules. It does not rename every commercial Gimel service "GAuth". No rights to implementations, patents, marks or proprietary combinations are granted by this memo.

Reading guide for insurance teams

In this document, a **mandate** is a machine-verifiable record of delegated business authority, not an insurance mandate, policy endorsement or automatic legal power of attorney. **Runtime enforcement** means checking and applying that authority immediately before an action is executed. **Monotonicity**, also described as contraction, means that a delegated assignment can become narrower but cannot silently become broader. A **platform decision** is the destination system's own permission check. **S1 and S2** are technical architecture labels, not insurance ratings; their underwriting significance is explained in §8.4. A **control boundary** is the set of transaction routes actually protected, not the whole enterprise unless that scope has been demonstrated.

2. Separate the control and insurance questions

Question	Relevant discipline
Who is acting?	Identity assurance and authentication
On whose behalf, within which current scope?	GAuth delegated-authority checks
Does the destination independently permit the action?	Platform authorisation and enforcement
Is the actor or activity suspicious?	Fraud-risk assessment and security controls
Is the output correct or safe?	Model evaluation, domain controls and professional review
Who is legally responsible?	Facts, contracts, causation and applicable law
Is the loss covered?	Policy wording, applicable law and claims assessment

CCPE means **Combined Credential- and Platform-Bound Enforcement**. In its S2 architecture, two structurally separate artifacts remain load-bearing: the principal-rooted mandate and the platform credential or capability. Decisions are reconciled without enlarging authority; platform denial cannot be overridden by a mandate. The relevant profile governs evaluation order and its exact requirements.

S1 denotes a platform-native, single-artifact authority arrangement without the separate mandate. S3 denotes a merged-credential arrangement, not a future target. S2 is the conformant scenario under the reviewed framework; separation alone is necessary but not sufficient for conformance. No lettered profile is assigned here without evaluating the actual substrate and integration.

Insurance itself is not an S1, S2 or S3 deployment.

3. Collaboration and responsibility model

Participant	Proposed role
Gimel Technologies	Support scoped implementation, control interpretation and evidence evaluation; state limitations
Gimel Foundation, where applicable	Steward published specifications and their change process; not underwrite or adjudicate claims
Insurer/reinsurer	Define relevant loss scenarios and independently determine evidence needs, insurability, terms and pricing
Broker	Clarify placement, policy interactions, gaps and overlaps
Insured enterprise/AI provider	Define valid delegations, operate controls, disclose changes and supply agreed exposure data
Relying party	Perform required verification and retain relevant notices, decisions and transaction records
Independent assessor	Test a stated deployment scope and disclose conflicts
Claims specialists/counsel	Evaluate causation, legal responsibility, coverage, contribution and recovery

Three collaboration routes are possible:

- **Enterprise-led pilot:** the insured deploys controls and asks its insurer to evaluate them.
- **Vendor assurance programme:** an AI provider demonstrates authority constraints alongside separately measured performance warranties.
- **Insurer risk-engineering programme:** an insurer offers an optional control-assessment pathway through Gimel and qualified independent assessors.

Implementation/support fees, assessment fees and insurance premiums remain distinct. Distribution, referral, confidentiality and data-sharing arrangements require separate agreements and applicable regulatory review. No insurer-specific exclusivity or

compulsory use of Gimel assessment services is proposed. Conformance assessment and insurer acceptance are separate decisions.

3.1 Normal course of business: underwriting and GAuth together

The following “happy path” describes a proposed integration of the **underwriting process** with the insured’s **delegation and transaction-control process**. It is an operating model for evaluation, not a currently deployed insurer interface.

Insurance stage	Insured’s GAuth control process	Evidence and underwriting use
Submission and exposure assessment	Identify agents, business activities, suppliers, transaction routes and existing approval limits	A schedule of controlled and uncontrolled activities; transaction volumes and values; dependency and concentration information
Risk engineering	Translate the insured’s approved delegation rules into signed, time-limited mandates; test enforcement and separate destination-system permissions	Evidence that stated limits are applied before execution; exceptions, bypass paths and residual risk
Quotation and binding	Confirm the operating scope and control baseline; agree change ownership and incident escalation	Carrier decides terms and any control-related representations or obligations. The policy and mandate remain separate records
Ordinary business	An authorised person grants an assignment; the agent requests an action; GAuth checks current authority; the destination also checks its own permissions	Action-specific record showing which principal authorised what, which checks passed and whether the action executed
In-period monitoring	Revoke or narrow assignments when needed; monitor exceptions, execution failures and changes	Agreed periodic exposure and control reports, rather than mandatory insurer approval of every action

Insurance stage	Insured's GAuth control process	Evidence and underwriting use
Incident and claims handling, if needed	Preserve the grant, notices, checks and actual execution records	Claims team distinguishes authorised error, exceeded authority and control failure; coverage is assessed separately
Renewal	Reconcile exposure, claims, control exceptions and changes against the declared baseline	Underwriter reassesses risk quality, uncertainty and terms using observed evidence, not a badge alone

One successful transaction

The insured's procurement manager authorises an agent to buy approved maintenance components from specified suppliers, up to EUR 1,000 per order, for the next 24 hours. The agent proposes an EUR 800 purchase. GAuth checks that the grant is genuine, current and applicable to this agent, supplier, product and amount. The purchasing platform independently verifies its own permission rules. Where a shared budget applies, the separately validated budget service reserves the required amount before commitment.

The supplier receives the order and the agreed authority evidence, verifies the applicable limitation, and acknowledges acceptance. The system records both permission to proceed and the actual order outcome. If either authority or platform permission is missing, execution stops or is referred to the insured's authorised decision-maker; an agent cannot enlarge its own spending power.

The underwriter receives agreed summaries and can obtain a minimised transaction-evidence sample for assurance or investigation. The insurer does not sign the purchase mandate, run the agent or warrant its decision. Buying the wrong component remains possible even when all authority checks pass.

Joining the records without confusing the limits

The insurance submission and control report identify the same deployment and control-baseline version. Individual transaction records identify the relevant mandate and executed action. This allows a risk engineer or adjuster to trace from the declared control to observed behaviour.

An operational spending limit is **not** a policy limit, deductible or coverage trigger. An internal authority breach does not automatically void cover, and an action within

authority is not automatically covered. Any reporting duty, control condition or consequence of non-compliance must be separately agreed in the policy and reviewed under applicable law. Material changes are handled through the insured's governance and any agreed insurer notification process, not through automatic policy amendments.

4. Causation and liability evidence

4.1 More than one cause can matter

An incident may combine model error, prompt injection, excessive initial authority, stale revocation information, a bypass and a relying-party failure. Labelling the incident "hallucination" is not an adequate causal analysis.

The proposed incident record distinguishes:

1. **Initiating mechanism:** model error, malicious input, internally generated misleading instruction, operator error or unknown.
2. **Authority state:** sufficient, absent, exceeded, expired, revoked, ambiguous or unverifiable.
3. **Control behaviour:** correctly blocked/permited, incorrectly permitted, bypassed or unknown.
4. **Relying-party evidence:** what was available, delivered, acknowledged, evaluated and overridden.
5. **Loss pathway:** executed action, actual damage, intervening events and alternative explanations.

Each conclusion identifies observed facts, supported inferences, disputed assertions and gaps. A signed decision is not proof of execution; a denial is not proof that all execution paths were blocked.

4.2 Incident matrix

Situation	Evidence to preserve	Underwriting/claims question
Valid authority; wrong action	Mandate, action, allow decision, model/application records	Is a covered AI-performance error involved?

Situation	Evidence to preserve	Underwriting/claims question
Excess authority; blocked	Denial, dispatch records, endpoint outcome and bypass checks	Was loss actually prevented, or had disclosure already occurred?
Excess authority; limitation acknowledged; execution proceeds	Exact notice, recipient, verification, override and transaction	What knowledge and duties are attributable, and how does this affect liability/recovery?
Excess authority; no adequate notice	Delivery failures, interfaces, missing records and verification duties	Was verification required and reasonably possible?
Revoked authority; action executes	Revocation, cache/freshness and execution timeline	Where did lifecycle enforcement fail?
Broad valid mandate permits harmful action	Grant, approval, scope reviews and activity history	Did delegation design contribute to the loss?
Denial bypassed through another route	Alternate credentials, connector and transaction records	Was the asserted control boundary incomplete?

4.3 Relying-party knowledge

“The relying party knew” should not be a single automatically inferred field. Distinguish information that was:

- **Available** for retrieval;
- **Delivered** to an identified endpoint;
- **Acknowledged** by an identified system or person;
- **Evaluated** with a recorded verification result;
- **Overridden or ignored** before execution.

A signed acknowledgement proves only what its authenticated semantics and supporting evidence establish. It is not conclusive proof of human understanding or legally attributable organisational knowledge.

Actual or constructive knowledge, apparent authority, ratification, contractual verification duties, causation and mandatory law require jurisdiction-specific review. Relying-party knowledge can be material without extinguishing another participant's liability. Evidence supporting recovery or contribution should not prematurely assign fault.

4.4 Worked example: procurement

Illustrative loss scenario, not observed claims data. A procurement agent has valid login credentials and permission to submit orders. The insured intends a EUR 1,000 per-order limit and a EUR 5,000 shared daily budget. Misleading supplier content causes the agent to attempt a EUR 12,000 order for an approved product. Assume the content filter does not flag it and the baseline purchasing API does not enforce those business limits.

Question	Without the additional GAuth control	With GAuth and the validated budget control
Can the request pass existing checks?	Yes in this defined baseline: identity is valid, API access is allowed and the content filter passes	Identity and API access still pass, but the separate EUR 1,000 mandate limit fails
What happens to the EUR 12,000 order?	It can be accepted; a financial commitment and resulting loss may follow	It is stopped before commitment on the protected route; the denial and non-execution are recorded
What if the agent splits it into smaller orders?	No tested shared-budget restriction is assumed	A separate, concurrency-safe budget mechanism is required to stop cumulative overspend; per-order GAuth checks alone are insufficient
What can the adjuster establish?	Identity and access logs may identify the actor, but the specific business grant may	Grant, scope, lifecycle, action, destination decision, notice and outcome are linked, subject to

Question	Without the additional GAuth control	With GAuth and the validated budget control
	require reconstruction from emails or internal policy	completeness and authenticity checks
What remains uninsured or uncontrolled?	Depends on wording, other controls, recovery and the loss facts	Still depends on wording; incorrect purchases within scope, indirect loss, compromised issuers and bypass routes remain relevant

Benefit to the insured and insurer: for the stated scenario, a tested authority check can prevent an unauthorised commitment; linked records can make investigation and recovery analysis more reliable. Fewer such events would support a frequency-reduction hypothesis. Narrower authority may restrict transaction exposure, while verified shared budgets may help manage accumulation. These are distinct propositions requiring separate evidence.

The EUR 12,000 order value is **not** a demonstrated EUR 12,000 avoided claim. Cancellation rights, recoveries, fulfilment, consequential damage and policy terms affect the actual loss. No expected-loss percentage or premium saving is inferred from this example.

Fair comparison: if the existing procurement platform already enforces the same limits, delegation, revocation and evidence requirements reliably across the same routes, it may block the order without GAuth. The incremental benefit must then be assessed in terms of independently evidenced business authority, consistency across systems, delegation controls and claims records—not credited again as a newly prevented loss.

For comparison, an EUR 800 purchase of the wrong component may proceed in both arrangements. It is an authorised performance error rather than an authority breach. That distinction helps the claims team investigate the relevant cause and policy section; it does not determine coverage.

5. Loss prevention: keeping delegated authority within approved limits

Generated plans, summaries, memory entries and sub-agent messages may contain instructions that influence later execution. “Self-generated prompt injection” and hallucination are not synonyms: investigators should identify whether instructions crossed a trust boundary or whether the event was another form of model/application error.

The proposed control principle is that generated content cannot itself mint, enlarge or override authority. A genuine extension requires an independently authenticated and authorised grant, not the agent’s claim that it needs more permission.

A pilot should demonstrate:

- child authority cannot exceed parent action/resource scope or validity;
- prompts, retrieved content, tool output and memory cannot override those restrictions;
- a plan or task assignment is not accepted as a mandate merely because an agent produced it;
- revocation and expiry remain effective through delegation and queued work;
- downstream constraints can narrow but not enlarge the effective authority;
- required platform denials and restrictions remain independently effective.

This constrains executable consequences, not all generation of malicious or false content. An injection may exploit permitted access, influence a validly authorised decision, or use an unmediated route. An over-broad mandate can authorise substantial harm.

5.1 Per-action limits are not aggregate limits

Repeated EUR 1,000 transactions can produce much larger total exposure. Financial budgets, rate limits and multi-agent caps require separate proof of atomic shared accounting, concurrency safety, replay prevention, retries, partial failure and transaction finality. These are pilot requirements where relied upon, not assumed features of every GAuth deployment.

6. Evidence for risk engineering and claims investigation

The following is a **proposed information model**, not an existing insurance API or standardised export. Map it to existing GAuth records and the future RFC 0050 export rather than asserting new wire fields.

Category	Purpose
Scope and exposure	Identify deployment, models, connectors, agents, resources, criticality, action volumes and exceptions
Conformance context	Identify applicable profile/version, claim validity, assessment scope, registry status where available and limitations
Mandate provenance	Principal/agent references, issuer, scope, chain, consent, validity and lifecycle evidence
Decision binding	Exact action/resource, mandate version, policy version and separate platform credential/capability and verdict
Time and freshness	Evaluation time, clock uncertainty, revocation source and freshness bounds
Enforcement/execution	Distinguish decision, dispatch, acceptance, final outcome, retries and duplicate handling
Relying-party record	Exact notice/limitation, recipient, delivery, acknowledgement, verification and override
Changes and incident linkage	Configuration/model changes, correlation, actual loss, recovery, disputes and causal evidence

Integrity protection, issuer authentication and action binding should make alteration and substitution detectable. Signatures do not establish completeness or truthfulness when issuers are compromised or paths are uninstrumented.

Agree versioned semantics, reproducible verification, omission/replay/clock-skew tests, incident preservation and documented custody. Missing evidence means unknown, not automatic compliance, fault or claim denial.

Minimise personal and proprietary data. The insurer should receive necessary assessment/claims evidence rather than unrestricted raw prompts, biometric material, confidential business records or credentials. Use access controls, lawful processing, redaction, retention/deletion schedules and appropriate cross-border arrangements. Hashes and pseudonyms are not automatically anonymous. Privilege and lawful evidence preservation need separate review.

7. What an underwriter can test and potentially recognise

7.1 Potential benefits and counter-effects

Verified controls may reduce unauthorised-action frequency, constrain loss severity, limit repeated/aggregate exposure and improve investigation. Better evidence may reduce uncertainty or claims-handling cost. Conversely, it may expose previously hidden risk and increase assessed exposure. False denials, latency and control outages may generate business interruption costs.

Insurers retain their own valuation methods. Conformance is evidence about a defined control scope, not an actuarial rating.

7.2 Exposure is not a premium formula

Economic value at risk depends on downstream effects, recovery, repetition and dependence. A EUR 10,000 transaction cap does not cap all resulting damage at EUR 10,000.

If statistical **Value at Risk** is used, specify the confidence level, time horizon and loss distribution. Consider expected loss and tail measures such as expected shortfall as well. A short pilot cannot validate rare extreme losses.

Premiums also reflect expenses, capital, reinsurance, limits, deductibles, exclusions and uncertainty. No discount or premium formula is proposed. A carrier may respond through different limits, deductibles, evidence terms, exclusions or no change.

7.3 Measurement plan

Use exposure-normalised measures:

- attempted violations, actual losses and action volume;
- execution after denial, bypass rate and repeated-action exposure;
- revocation propagation and end-to-end enforcement latency;
- evidence completeness and successful incident reconstruction;

- severity, recovery and aggregate/correlated loss where observable;
- false denials, overhead and business interruption;
- changes in users, models, action mix, connectors and operating conditions.

Compare matched workloads, historical baselines or safe simulations; document confounders, sample size, uncertainty and selection effects. Blocked attempts are not automatically avoided claims. Red-team tests establish control behaviour, not actuarial loss reduction. Do not remove essential safeguards from live high-risk operations to construct a control group.

8. aiSure and Instnt illustrations

8.1 Munich Re aiSure

Documented: Munich Re describes aiSure as covering specified AI-related contractual liabilities, own financial losses and legal liabilities. Its FAQ discusses development-pipeline review, data drift, statistical risk estimation and performance-risk pricing research. Its corporate factsheet describes tailored cover, deductibles, co-insurance, sub-limits and insurable penalties.[1–3]

A proposed collaboration would select one insured agent use case, separate performance errors from authority failures, validate GAuth controls and compare resulting exposure/evidence. The insurer would decide whether the findings affect terms.

An unauthorised action is not automatically an insured “AI error”. Depending on cause and wording, it may intersect with cyber, crime, professional indemnity, technology errors and omissions, contractual liability or other cover—or be excluded. A performance warranty needs its own measurable insured event; authority conformance alone proves neither accuracy nor ROI.

No reviewed source establishes Munich Re acceptance of GAuth, an integration, a discount or a claims format.

8.2 Instnt: identity/fraud decisioning, not merely a content guardrail

Documented: Munich Re’s 2026 case study describes Instnt’s Identity Decision Model, using behavioural, device, document-authenticity, digital-footprint and identity-bureau signals to estimate fraud risk and expected loss, combined with fraud-loss insurance backed by a reinsurance panel led by Munich Re.[4]

This is substantive risk decisioning plus financial protection. It should not be reduced to an LLM content filter. Marketing language about complete liability transfer or zero fraud

losses is not repeated here as an unconditional promise; policy terms and availability govern.

Evidence-bounded classification: on the delegated-authority axis, the described identity-based arrangement is **S1-aligned**: the case study does not demonstrate a separate principal-signed, scoped, revocable agent mandate and action-bound enforcement. This is an analogy for the described baseline in an agent deployment, not certification of Instnt, a complete architecture audit, or proof that all private implementations lack these capabilities. Ordinary identity-fraud screening outside agent delegation does not itself require an S-classification.

8.3 Proposed S1-to-S2 integration

Keep four distinct responsibilities:

1. **Instnt assessment:** identity/fraud-risk evidence, with its version, time and limits.
2. **GAuth authority:** a separate principal-rooted mandate evaluated for the actual action.
3. **Platform permission:** the destination's separate credential/capability and qualifying authorisation decision.
4. **Execution enforcement:** apply the restrictive combination before the consequential action, preserving action binding and preventing bypass.

Instnt evidence can inform supplementary review or veto; it cannot grant missing authority. A probabilistic score, even wrapped in a deterministic threshold, is not by itself a qualifying deterministic CCPE evaluator. Two software services are not two authority artifacts. Identify the platform artifact's issuer, lifecycle and action binding and validate the relevant profile's ordering and controls before claiming S2.

No particular lettered CCPE profile is assigned here: identity onboarding, commerce execution and protected-data processing can involve different substrates.

A genuine, low-risk identity can lack authority. A validly authorised actor can still commit fraud. The combination addresses different risk dimensions without making either control redundant.

8.4 Existing safeguards, agent identity and GAuth: incremental underwriting value

The limitation is not that existing controls have no insurance value. Content safeguards, fraud screening, least-privilege access and agent identity management can materially improve risk quality. Their underwriting contribution is narrower where the

question is: *what business authority did this particular agent have for this particular transaction, and was that authority enforced?*

Content guardrails and S1 are not the same thing

“Guardrails” can mean content filters, prompt-injection detection, safety classifiers, deterministic transaction rules, human approvals or tool restrictions. They are not one homogeneous technology. Some are probabilistic; others enforce hard limits. Insurers should ask what each control actually prevents, on which routes and with what tested failure rate.

S1 describes a deployment that relies on platform-native identity and permissions without the separate GAuth mandate. A guardrail can be present in either S1 or S2. It is therefore misleading to label every guardrail solution S1, or to infer that an S1 deployment has no effective loss-prevention controls.

Entra Agent ID: valuable access controls, not automatically a business mandate

Microsoft’s public documentation describes Entra Agent ID as an authentication **and authorisation** framework, including agent identities, restricted role assignments, delegated permissions acting on behalf of users, administrator-consented application permissions and inheritable permissions.[7] These are substantive preventive controls—not merely monitoring or an identity label.

Delegated API permission, however, is not automatically evidence of a separately signed business instruction with a particular amount, supplier, purpose, expiry and non-expanding delegation chain. The cited documentation does not by itself demonstrate that complete GAuth mandate-and-enforcement arrangement for the procurement example. Calling Entra Agent ID an “ID-bound mandate” should not imply that Microsoft already supplies the identical artifact or every control discussed here.

For an underwriter, Entra can help answer **which agent is recognised, who it can act for, and which resources it can access**. GAuth’s proposed additional contribution is **which specific assignment the responsible principal has authorised, within which limits, and whether those limits were applied at execution**. Preserve Entra’s permissions and safeguards; add and test the mandate layer rather than replacing identity management.

Underwriting comparison

Underwriter's concern	Existing guardrail/identity contribution	Additional evidence sought from GAuth
Unauthorised action frequency	Content screening, restricted API access and approval controls may prevent harmful actions	Tested rejection of actions outside the separately granted business assignment, even when identity and content checks pass
Severity and accumulation	Native transaction limits may already constrain exposure	Demonstrated assignment-specific limits and non-expanding delegation; aggregate benefit only where shared accounting is separately proved
Revoked or changed authority	Identity and platform access can be disabled or changed	Evidence of assignment withdrawal or narrowing and the delay until this is effective at the actual execution boundary
Claims attribution	Logs identify sessions, resources, alerts and access decisions	Linked grant, exact action, relying-party notice/response and execution record to distinguish authority breach from authorised error
Confidence in declared controls	Vendor features and configuration attestations describe available safeguards	Deployment-specific tests showing the additional mandate control is active, complete and not bypassed

How the value would appear in an underwriting file

Record the baseline safeguards first. Then state the additional GAuth control, the risk scenario it addresses, the tested scope, evidence quality and remaining uncertainty. For example: “Independent business-authority checks demonstrated for the specified procurement route; out-of-scope orders blocked in the agreed test set; revocation and transaction evidence verified; shared-budget control assessed separately; other routes excluded from this conclusion.”

The carrier can then assess whether that evidence supports better risk selection, reduced uncertainty, a different retention or limit, fewer exclusions, or a pricing review. It may conclude that existing controls already provide equivalent protection or that the evidence is insufficient. No automatic underwriting credit should attach to either the S2 label or the GAuth name.

Where a vendor supplies a genuine identity-bound mandate, assess its actual properties rather than the label: who grants it, who can alter it, how scope narrows, how withdrawal propagates and how the destination enforces it. A single merged credential is not automatically proof of no insurance value. GAuth's structural distinction is a separately verifiable principal-rooted mandate alongside platform permission, with the more restrictive outcome controlling execution.

8.5 ERGO NEXT: a potential application of authority-aware underwriting in small-business insurance

Business context

ERGO NEXT Insurance illustrates how authority-aware underwriting could complement a digital commercial insurer's existing business model.

The Munich Re Group completed its acquisition of NEXT Insurance on 1 July 2025, placing the company within ERGO's management structure. In January 2026, NEXT adopted the ERGO NEXT Insurance brand. Its focus is insurance for US small businesses, including General Liability, Professional Liability / Errors and Omissions, Workers' Compensation and Business Owners Policies. It also provides embedded insurance distribution through business partners.

ERGO NEXT states that it uses artificial intelligence in pricing, underwriting, distribution, customer service and claims administration. This distinguishes two different subjects:

- AI used by the insurer: technology supporting its own insurance operations.
- AI used by the insured: technology creating or changing the policyholder's business exposures.

GAuth could be evaluated in either setting. The primary focus of this RFC is the second: whether enforceable limits on an insured's AI agents, together with reliable transaction evidence, improve loss prevention and underwriting.

This is an illustrative application, not an announced partnership, an existing GAuth integration or a statement that ERGO NEXT offers specific cover for every loss scenario discussed below.

A risk already recognised by NEXT

In its published outlook for 2026, NEXT identifies agentic AI misuse as a potential driver of “blended liability claims”: losses involving more than one insurance coverage. Examples include incorrect client deliverables, privacy breaches and leakage of intellectual property. NEXT also identifies a need to clarify coverage definitions, underwriting guidelines and which insurance line responds to AI-related errors.

For an underwriter, the issue is not simply whether a business uses AI. Relevant questions include:

- What consequential actions can its agents perform?
- Who authorised those activities, and within which limits?
- Are those limits enforced before a transaction or disclosure occurs?
- Can authority be withdrawn promptly?
- What evidence will be available if a loss involves several parties or policies?

These questions provide a practical basis for evaluating GAuth alongside existing security, identity and business controls.

Complementary responsibilities

ERGO NEXT’s publicly described role is to assess, price, distribute and administer insurance. GAuth’s proposed contribution is to verify and enforce the business authority granted to an agent before it acts.

Underwriting or claims concern	Potential GAuth contribution	Decision retained by the insurer
Unauthorised transactions or disclosures	Tested rejection of actions outside a current, separately granted mandate	Whether the control materially changes the insured risk
Excessive delegated authority	Assignment-specific limits and delegation that cannot silently expand those limits	Whether the scope and reliability justify underwriting recognition
Repeated or correlated losses	Evidence of authority limits; aggregate controls where separately implemented and tested	Assessment of accumulation, dependencies and residual exposure
Uncertain circumstances of loss	Linked records of the grant, requested action, checks, notices and actual execution	Causation, coverage, adjustment and recovery assessment

Underwriting or claims concern	Potential GAuth contribution	Decision retained by the insurer
Changes during the policy period	Evidence of mandate changes, withdrawals and control exceptions	Any reporting requirements and contractual consequences

GAuth does not replace fraud screening, identity management, content safeguards, professional review or the destination system's own permissions. Nor does it replace the insurer's risk model.

The reviewed public sources do not establish a GAuth-equivalent, separately signed and action-bound mandate arrangement within ERGO NEXT's offering. That is a limit of the available evidence, not proof that comparable controls are absent from all of its internal systems or customer implementations. ERGO NEXT itself should not be classified as an S1 or S2 architecture: those labels concern particular technical deployments, not insurance companies.

Illustrative insured scenario: an agent discloses client information

Consider a small professional-services firm whose agent prepares client reports. The agent has legitimate access to working files, but its current assignment permits external delivery only to an approved client recipient and only after the required review.

Misleading instructions in a retrieved document cause the agent to attempt to send confidential material to an unrelated external address.

Without a separately enforced business-authority check, the disclosure may proceed if the agent's standing access rights permit sending the material and existing safeguards do not detect the problem. Identity logs may establish which account acted without conclusively establishing the specific instruction under which it was entitled to act.

With the proposed GAuth integration, the disclosure request is checked against the current mandate, including the permitted recipient, relevant data scope and any required approval. If the request exceeds that authority, it is stopped before transmission through the protected route. The destination's own access and security controls remain independently applicable.

This example assumes that the restrictions can be expressed and verified, that the relevant transmission paths are covered, and that enforcement occurs before disclosure. GAuth does not by itself determine whether arbitrary document content is confidential or factually correct. Data identification and classification may require separate controls.

If the same material is sent to the approved recipient within valid authority but contains incorrect professional advice, an authority check may legitimately permit it. The resulting loss would require a different analysis.

For the insurer, the benefit is therefore twofold:

1. Loss prevention: a demonstrated ability to stop a defined class of unauthorised disclosures.
2. Claims differentiation: better evidence for distinguishing an authorised professional error from an authority breach, a control failure or a relying-party override.

Neither outcome automatically determines whether Cyber, Professional Liability or another policy responds. Applicable wording, exclusions, causation and the actual loss remain decisive. Where existing controls already prevent the same disclosure, their benefit must not be counted again as an incremental GAuth improvement.

A proportionate evaluation for a small-business portfolio

A practical collaboration could extend the pilot approach in Section 10 to one narrowly defined customer activity, such as procurement or external delivery of professional work.

The insurer and participating businesses would first identify the loss scenario and existing safeguards. Gimel would then demonstrate the additional authority controls and evidence available for that scenario. An independent assessment could test the declared scope, including bypass routes, withdrawal of authority and incomplete records.

The evaluation should measure:

- actions executed outside approved authority;
- control failures and exceptions;
- false denials and disruption to legitimate work;
- the completeness and usefulness of claims evidence;
- exposure-normalised losses, where sufficient observations exist;
- implementation and operating costs.

For small businesses, proportionality matters. A technically strong control may have limited commercial value if it is too expensive or difficult to operate. Integration through an existing business-software provider or embedded distribution partner may offer a more practical route than a separate installation for every policyholder. This is a proposed delivery model, not an existing ERGO NEXT arrangement.

Successful tests could support further risk-engineering work, different evidence requirements or a review of terms. They would not, on their own, justify a premium reduction or prove a reduction in rare or severe claims.

Potential relevance to the insurer's own operations

A separate evaluation could examine authority controls for the insurer's own AI-enabled processes. If agents are permitted to amend contracts, communicate binding decisions or initiate payments, the insurer may need explicit limits on those actions and reliable evidence of approval.

ERGO NEXT's disclosed use of AI does not establish that it currently delegates those consequential activities to autonomous agents. This is therefore a possible future application, not a description of its present operating model.

9. Brief outlook: identity and post-quantum exposure

For insurer discussions, distinguish **Gimel ID** (identity-assurance/binding concepts in RFC 0200), **GAuth** (delegated action authority) and **Gimel PQC** (a descriptive portfolio label for cryptographic-resilience work, not a new protocol defined here). The reviewed authentication specification calls its framework **GAuthent**, RFC 0300; it is not GAuth.

AI-assisted fraud is a present concern. Quantum-assisted AI fraud is a forward-looking scenario, not an established inevitability or a dated forecast. The better-established threat is that sufficiently capable quantum computers could compromise vulnerable public-key key establishment and signatures. **Harvest-now-decrypt-later** concerns future disclosure of data captured today; future signature compromise separately threatens credentials, mandates and evidentiary authenticity.

Insurers should ask about cryptographic inventories, standards-based migration and agility, key/credential lifecycle, downgrade protection, confidentiality horizons and preservation of long-lived verification evidence through trusted time and suitable archival renewal.

10. Evaluation programme

Stage	Work	Decision gate
1. Scope	Use case, parties, jurisdiction, insured interest, loss scenarios and current policies	Insurer confirms relevance and potential insurability
2. Design	Map action paths, mandates, relying-party notices, evidence, privacy and assumptions	Agree implemented, missing and testable controls
3. Validation	Narrowing, revocation, expiry, generated instructions, bypass, replay, concurrency and evidence integrity	Resolve or disclose critical gaps
4. Observation	Bounded operation with essential safeguards maintained	Adequate exposure and evidence quality for qualified conclusions
5. Underwriting review	Assess results, operational costs, uncertainty and coverage interactions	Change terms, extend evaluation or decline
6. Ongoing assurance	Monitor changes, failures, exceptions and dependencies	Maintain recognition only on agreed conditions

Before the pilot, agree owners, access rights, success criteria and stop conditions. Execution after denial, unexplained evidence gaps or failure of an assumed shared budget are possible stop conditions. Define notification and remediation; do not invent automatic policy cancellation or claim rejection.

Deliver a control-boundary map, evidence specification, test report, incident-analysis template, exposure dataset and insurer assessment. Duration and sample size depend on the use case.

10.1 Minimum test scenarios

The test report should record expected outcome, observed outcome, evidence and residual limitations for:

- a legitimate action within both mandate and platform scope;
- a genuine identity requesting an action outside its mandate;
- a low-risk fraud score accompanying absent authority;
- a child agent attempting to widen scope;
- generated instructions attempting to bypass a restriction;
- revocation during queued work and stale/replayed decisions;
- a relying party acknowledging a limitation then overriding it;
- concurrent/retried actions near an aggregate limit;
- loss or corruption of evidence and control-service outage.

Use synthetic identities/data where possible and avoid intentional harmful real-world transactions.

10.2 Concrete pilot: bounded procurement-agent purchases

Proposed, illustrative and not yet agreed with an insurer. An enterprise uses an agent to buy approved maintenance components from participating merchants. Gimel supports the authority integration; the enterprise operates it; an interested insurer or reinsurer evaluates the evidence. A broker and counsel map the scenarios to candidate cover. An independent assessor verifies the agreed control boundary. Neither Munich Re nor Instnt is assumed to participate.

Scope and authority

For this pilot, propose a maximum of **EUR 1,000 per order**, an **EUR 5,000 shared daily purchasing budget** across the participating agents, approved suppliers and product classes, and a **24-hour mandate validity window**. These are illustrative test parameters, not product defaults, recommended insurance limits or bounds on consequential loss. The enterprise approves them before use.

The mandate identifies the principal, agent, permitted purchases, resources, validity and delegation constraints. A child agent may narrow but not increase these permissions. Independent platform credentials and permissions remain separate. Purchasing authority does not include changing payment destinations, expanding the supplier list or granting further authority beyond the approved delegation.

The integration covers request creation, merchant acceptance and order execution. An authenticated limitation notice and its verification result are bound to the exact order. Any merchant or alternate ordering route not covered by the integration is documented as outside scope; coverage of one route must not be presented as enterprise-wide protection.

The shared daily budget requires an atomic reservation/commit/release mechanism across agents, with an agreed day boundary and handling of retries, cancellations and partial fulfilment. GAuth mandate checks alone are not assumed to implement that accounting. If the mechanism cannot be demonstrated, the pilot must not claim an aggregate cap.

Loss scenarios and evidence

Scenario	Expected control or observation	Insurance question
Approved EUR 800 purchase	Both authority and platform checks pass; record final execution	Baseline legitimate activity
EUR 1,500 order	Deny before execution	Does the control restrict unauthorised financial exposure?
Permitted EUR 800 order for the wrong component	May execute within authority; retain application evidence	Could a defined AI-performance error and resulting loss be covered?
Two agents race near the daily budget	Shared accounting prevents budget overspend	Is the asserted aggregation control effective?
Generated instruction changes the supplier or payment destination	Deny the unapproved change	Does misleading content gain executable authority?
Revoked mandate on a queued order	Re-check at the agreed execution boundary and stop the invalid action	Where is residual revocation exposure?

Scenario	Expected control or observation	Insurance question
Merchant acknowledges an over-limit notice and accepts anyway	Simulate only; retain notice, acknowledgement, override and outcome	How does attributable knowledge affect liability or recovery?

The evidence package links mandate/version, parent delegation, platform decision, exact order, current lifecycle check, budget reservation, relying-party notice, acknowledgement, execution outcome and any measured loss. Store minimal necessary commercial information under agreed access and retention controls.

Proposed sequence and gates

- Weeks 1–2: scope and wording workshop.** Enterprise, insurer, broker and counsel agree the insured interest, candidate loss events, exclusions, verification duties and data-sharing basis. Deliver a one-page scope and coverage-question register; no cover is inferred from participation.
- Weeks 3–4: sandbox validation.** Gimel and the enterprise demonstrate the listed scenarios with synthetic data and simulated payments. The assessor checks bypass paths, replay, concurrency, revocation and evidence integrity. Material failures block live progression.
- Weeks 5–8: bounded observation, if approved.** Observe legitimate activity with existing safeguards intact. Use safe replay or simulation for deliberate violations and merchant overrides. Record action volume and mix; eight weeks is an illustrative schedule, not an actuarially sufficient sample.
- Close-out: independent underwriting review.** Compare the evidence with an agreed historical or matched baseline, report confounders and uncertainty, and decide whether to extend observation, alter terms or take no action.

Before observation, the insurer and enterprise agree measurement targets and minimum exposure. Proposed technical gates are no unauthorised execution in the defined adversarial test set, no demonstrated shared-budget overspend, and successful reconstruction of every test transaction. Passing these gates does not establish a zero failure rate in production.

Report executed orders, attempted violations and actual losses with denominators; severity/recovery where observed; execution after denial; budget failures; end-to-end

revocation latency; evidence completeness; false denials and operational cost. Treat blocked attempts separately from avoided claims.

Stop and investigate on execution after denial, unexplained evidence gaps, aggregate-limit failure or an unapproved action path. The enterprise disables the affected path; Gimel supports diagnosis; the insurer receives notice under the separately agreed process. The policy—not this RFC—determines coverage consequences.

Deliverables and possible outcome

The pilot produces a scope/control map, test report, minimised transaction-evidence sample, exposure dataset, causal-analysis examples and an insurer-owned assessment. Potential outcomes include better evidence requirements, changed deductibles or limits, a pricing review, a longer pilot or no commercial change. No favourable underwriting decision is promised.

11. Policy, legal and operational questions

Resolve before commercial adoption:

1. What exactly is the insured event, and how is “AI error” defined?
2. How are authority breaches, authorised errors and malicious interference treated?
3. What verification duties apply to the relying party?
4. How do notice, knowledge, override, ratification and missing evidence affect analysis?
5. Which controls are representations, warranties, conditions or recommendations?
6. What happens when controls change, fail or are temporarily unavailable?
7. How do aggregation, deductibles, causation, recoveries and overlapping policies interact?
8. What independent challenge/review protects insureds and third parties?
9. What privacy, privilege, insurability and cross-border restrictions apply?

Residual risks include compromised principals/issuers, disputed mandates, excessive initial authority, stolen credentials, endpoint collusion, stale verification and unmediated paths. Shared authority infrastructure can create correlated loss or outage exposure across insureds. Fail-closed behaviour can interrupt legitimate work; exceptions can reintroduce risk. Both belong in the assessment.

No automatic log classification is a conclusive coverage decision. Neither conformance nor insurance guarantees safety.

12. Request for comments and next step

Insurers, reinsurers and brokers are invited to identify:

- the loss scenario most likely to benefit from authority evidence;
- the relying-party knowledge evidence useful for investigation;
- the controls and measurement needed to influence underwriting;
- gaps between model-error cover and authority-related losses;
- acceptable data-sharing and independent assessment arrangements.

A practical initial response can state the proposed use case, jurisdiction, policy class, desired evidence and evaluation lead. The first joint workshop should produce a one-page pilot scope, not a coverage commitment.

Proposed outcome: a carrier-neutral evidence and loss-control collaboration in which Gimel demonstrates authority boundaries and insurers independently assess their economic and legal relevance.

References

Public sources reviewed 25 September 2026. Product descriptions are not binding policy wording.

1. Munich Re, **aiSure — More AI Opportunity. Less AI Risk.**
<https://www.munichre.com/en/solutions/for-industry-clients/insure-ai.html>
2. Munich Re, **AI insurance frequently asked questions.**
<https://www.munichre.com/en/solutions/for-industry-clients/insure-ai/faq.html>
3. Munich Re, **AI Insurance for Corporates**, © 2025.
https://www.munichre.com/content/dam/munichre/contentlounge/website-pieces/documents/AI-Insurance-for-Corporates.pdf/_jcr_content/renditions/original./AI-Insurance-for-Corporates.pdf
4. Munich Re, **Case Study: Instnt — AI-enabled tool for loss management in business fraud**, 2026-018, New 02/26.
https://www.munichre.com/content/dam/munichre/contentlounge/website-pieces/documents/2026-AI-MR-Instnt-Case-Study-Instnt.pdf/_jcr_content/renditions/original./2026-AI-MR-Instnt-Case-Study-Instnt.pdf
5. NIST, **What Is Post-Quantum Cryptography?**
<https://www.nist.gov/cybersecurity-and-privacy/what-post-quantum-cryptography>
6. NIST, **Post-quantum cryptography.**
<https://www.nist.gov/pqc>
7. Microsoft Learn, **Authorization in Microsoft Entra Agent ID**, last updated 12 June 2026; reviewed 25 September 2026.
<https://learn.microsoft.com/en-us/entra/agent-id/authorization-agent-id>
8. ERGO, **“ERGO successfully finalizes the full acquisition of NEXT Insurance”**, 1 July 2025.
<https://www.ergo.com/en/newsroom/media-information/2025/20250701-ergo-acquisition-next-insurance>
9. NEXT Insurance, **“NEXT Insurance rebrands as ERGO NEXT Insurance”**, 15 January 2026.
<https://www.nextinsurance.com/blog/next-insurance-rebrands-as-ergo-next-insurance/>
10. ERGO NEXT Insurance, **“Partner With Us”**.
<https://www.nextinsurance.com/become-a-next-insurance-partner/>
11. ERGO NEXT Insurance, **“Artificial Intelligence Terms”**, revised 14 January 2026.
<https://www.nextinsurance.com/artificial-intelligence-terms/>

12. NEXT Insurance, “**AI and the future of small business insurance: 2026 predictions**”.

<https://www.nextinsurance.com/blog/ai-small-business-insurance-predictions/>

Specification alignment

The discussion was checked against project-held GiFo-RFC 0210 (identity/authority separation), and RFC 0141 (§4.1 monotonicity). RFC 0200 names Gimel ID; RFC 0300 names GAuthent. These references identify architectural alignment, not certification or evidence of deployed insurer capabilities.

* * *

Disclaimer: ALL DOCUMENTS AND THE INFORMATION CONTAINED THEREIN ARE PROVIDED ON AN “AS IS” BASIS AND THE CONTRIBUTOR, THE ORGANIZATION THEY REPRESENT OR ARE SPONSORED BY (IF ANY), THE GIMEL FOUNDATION, AND ANY APPLICABLE MANAGERS OF ALTERNATE DOCUMENT STREAMS, DISCLAIM ALL WARRANTIES, EXPRESS OR IMPLIED, INCLUDING BUT NOT LIMITED TO ANY WARRANTY THAT THE USE OF THE INFORMATION THEREIN WILL NOT INFRINGE ANY RIGHTS OR ANY IMPLIED WARRANTIES OF MERCHANTABILITY OR FITNESS FOR A PARTICULAR PURPOSE.

PRODUCT NAMES, TRADEMARKS, AND REGISTERED TRADEMARKS REFERENCED IN THIS DOCUMENT ARE THE PROPERTY OF THEIR RESPECTIVE OWNERS AND ARE USED FOR IDENTIFICATION PURPOSES ONLY. NO ENDORSEMENT IS IMPLIED.

* * *